P4

Contrastar hipótesis con GDB — Criterios y solución docente

Parte I · RA4 · 4 h

Universidad de Almería · Edición de 27 de septiembre de 2026

Documento: Criterios y solución de referencia
Asignatura: Ingeniería Inversa y Análisis Forense Digital
Uso: Laboratorio docente en entorno controlado y sobre las muestras indicadas
Alumno/a: _____ Grupo: _____

Material reservado para corrección docente

Este documento contiene criterios de corrección y resultados de referencia. No debe incorporarse al paquete evaluable que recibe el alumnado.

Índice

1. Calentamiento **2**

2. Desarrollo de referencia **2**
2.1. Qué demuestra la intervención 2
2.2. PIE/ASLR 2

3. Corrección de RE-01 **2**

4. Lista de corrección **3**

5. Solución RE-01 1.0 — actualización de 28 de septiembre de 2026 **3**
5.1. Solución de la intervención 3
5.2. PIE y alcance de las observaciones 4

> **Estado actual: RE-01 1.0 disponible.** La actualización del 28 de septiembre de 2026, al final del documento, contiene el material definitivo y sustituye las menciones a RE-01 pendiente de producción. Las fichas anteriores se conservan como antecedente.

Material para el profesorado. No incluir en el paquete evaluable del alumnado. No se tratan como secretos los fuentes o soluciones publicados en el repositorio.

1 Calentamiento

Trece `A` tienen longitud correcta pero contenido incorrecto; la validación devuelve 0 y el programa retorna 1. La clave válida de P3 produce validación 1 y salida del programa 0. Una cadena vacía se rechaza por longitud. Se comprueba con el fuente y con ejecución del build concreto, sin suponer offsets de una captura anterior.

Tras `finish` de `validar_contrasena`, antes de que el llamante consuma el retorno, `set $eax = 1` puede forzar éxito en esa ejecución. Se exige explicar el punto exacto, el control sin cambio y la recuperación de comportamiento normal en otra ejecución. Cambiar flags antes de un `cmp` posterior que los sobrescribe no es un bypass válido.

Para RE-01 se completa la solución al producir el caso: cinco entradas, esperados, observados y efectos sobre archivos. No se califica el uso de un comando por sí solo: la operación debe responder una hipótesis y permitir repetirla. Una observación que refuta una predicción bien planteada tiene valor; se actualiza la especificación.

Rúbrica y pesos: evaluación de Parte I.

2 Desarrollo de referencia

La muestra produce siempre la línea `retorno=42 if=1 bucle=45 llamada=6`. Sin argumento muestra uso y retorna 1. Con 13 letras A informa contraseña incorrecta y retorna 1; con `R3v3rs1ng_UAL`, correcta y retorna 0.

En la sesión observada, `info args` y `x/s` deben relacionar puntero y cadena. Tras `finish`, `eax=0` para una entrada inválida. Cambiarlo a 1 antes de la rama del llamante hace que esa sesión tome el camino de éxito. El control posterior sin intervención debe volver a fallar.

2.1 Qué demuestra la intervención

Demuestra que el llamante confía en un retorno alterable y que la decisión observada puede forzarse en ese proceso. No demuestra que la cadena inválida pase el algoritmo, que el fichero esté parcheado ni que esa intervención ocurriera históricamente.

2.2 PIE/ASLR

Se corrige el procedimiento y la comprobación de instrucciones, no una base fija. Una dirección efectiva copiada de otra ejecución pierde validez. Si el entorno impide `ptrace`, se registra como incompatibilidad y se realiza en la VM preparada.

En el contenedor de validación actual, GDB no pudo iniciar el inferior por `ptrace: Operation not permitted`; por tanto, no se presenta una falsa sesión exitosa local. Las salidas semánticas anteriores sí se comprobaron sin depurador.

3 Corrección de RE-01

La tabla real de cinco pruebas se añade al producir el caso. Debe contener controles, retornos, stdout/stderr y efectos. Una predicción refutada puede alcanzar máxima calificación si se explica y corrige la especificación.

4 Lista de corrección

- Control anterior a la intervención.
- Logging y localizadores reproducibles.
- Resolución PIE basada en el proceso actual.
- Cinco pruebas con una variable discriminante.
- Efectos observados y controlados.
- Valor original registrado antes de cambiarlo.
- Conclusiones limitadas a la ejecución.

5 Solución RE-01 1.0 — actualización de 28 de septiembre de 2026

Esta sección completa el ejercicio central y actualiza el estado anterior. GDB se ha ejecutado con ptrace permitido fuera del sandbox; el bloqueo documentado arriba corresponde a la revisión previa. Los resultados completos, hash y logs están en la validación RE-01.

Prueba	Retorno	stdout	Etapa en stderr	Resultado
RE-01.T1	0	ID 1042, 17 bytes, d8d9f468	done	fichero con HTXLSR DOID 2026.
RE-01.T2	5	vacío	document	no creado
RE-01.T3	0	ID 1042, 16 bytes, 84929ef5	done	fichero con DEFGHIJKL-MNOPQRS
RE-01.T4	6	vacío	limit	no creado
RE-01.T5	4	vacío	config	no creado

stderr tiene la forma exacta RE01 status=N stage=ETAPA seguida de LF. stdout en T1 es OK id=1042 bytes=17 checksum=d8d9f468 seguido de LF. El informe JSON conserva los bytes de texto de todas las salidas. Reutilizar una salida existente produce retorno 7, etapa write, sin modificar su contenido.

5.1 Solución de la intervención

Use una copia de trabajo de los directorios alumnado y docente. Dentro de docente, inicie GDB y cargue el ELF stripped y sus símbolos correspondientes. La ruta del resultado siguiente no debe existir:

```
set pagination off
set disable-randomization off
file ../alumnado/RE-01
symbol-file RE-01.debug
set args ../alumnado/entradas/limite.cfg ../alumnado/entradas/exceso.txt intervenido.txt
break load_config
run
set $saved_cfg = cfg
finish
p $saved_cfg->limit
set $saved_cfg->limit = 17
p $saved_cfg->limit
continue
```

Se conserva el puntero antes de salir de load_config porque el nombre local cfg deja de estar en ese marco. El control original retorna 6; la intervención produce la salida de 17 bytes; el control posterior retorna de nuevo 6. verificar.py comprueba la salida intervenida contra el oráculo, además de ambos controles. Parar en transform_record no sirve para intervenir T4: no se alcanza esa función cuando el límite es 16. Se modifica el estado de un proceso, no su ejecutable.

5.2 PIE y alcance de las observaciones

En dos sesiones registradas, main se cargó en 0x57648466da70 y 0x55c1f8357a70. Su VA ELF es 0x1a70; al restarla resultan bases distintas 0x57648466c000 y 0x55c1f8356000, coherentes con los mapeos registrados. Para una sesión nueva se repite el cálculo. La comparación del límite está en VA 0x1b17 y el jb en 0x1b1e.

En strace se debe buscar creación exclusiva de la salida y relacionar operaciones con descriptores, no con el orden aparente de mensajes de buffers de stdio. Esto es una predicción apoyada en el código: strace no está instalado en el entorno de validación actual y no se adjunta una traza como observada. Debe completarse en la VM del curso. Las 97 pruebas funcionales y las dos sesiones GDB sí se han ejecutado.